

Date: March 2026

Comprehensive Analysis

Report: Hands-On Email Threat Investigation

Prepared for: Career247 Cybersecurity Capstone Project

Prepared by: Mukul Kumar

Table of Contents

1. Executive Summary
2. Investigation Methodology & Environment Setup
3. Email Header & Authentication Forensics
4. Content, Link, and Social Engineering Analysis
5. Attachment Forensics and Payload Assessment
6. Threat Intelligence Correlation & Framework Mapping
7. Automated Threat Scoring Evaluation
8. Actionable Recommendations and Remediation
9. References
10. Appendices

1. Executive Summary

1.1 Overview of the Incident This report serves as the primary deliverable for the Career247 "Hands-On Email Threat Analysis" Capstone Project. The objective is to conduct a comprehensive forensic analysis of a suspicious .eml file, determine its risk level, and provide actionable remediation recommendations.

1.2 Key Findings & Final Verdict Following a systematic forensic analysis within an isolated sandbox environment, the email is classified as **Confirmed Phishing** with a **High-Risk Level**.

The threat actor executed a mass-market credential harvesting campaign utilizing the following tactics:

- **Brand Impersonation & Typosquatting:** The sender utilized the unauthorized domain `secure-paypal.com` to bypass superficial user scrutiny.
- **Infrastructure Abuse:** The malicious payload was hosted on Vercel (`paypalphish.vercel.app`), explicitly abusing legitimate cloud infrastructure to evade reputation-based security gateways.
- **Decoy Payload:** While the email contained a .docx attachment, forensic analysis proved it was a benign ASCII text file serving as a placeholder.

1.3 Automated Threat Score Utilizing a custom-built AI-assisted threat scoring matrix, the email scored **36/100 (Suspicious)**. However, manual correlation upgrades the operational severity to High due to the evasive techniques employed.

1.4 Critical Containment Actions Immediate perimeter blocking of the malicious domain (`paypalphish.vercel.app`) and originating IPs (`45.67.89.101`, `185.203.114.77`) is required. Furthermore, the organization must enforce a DMARC "reject" policy to mitigate domain spoofing.

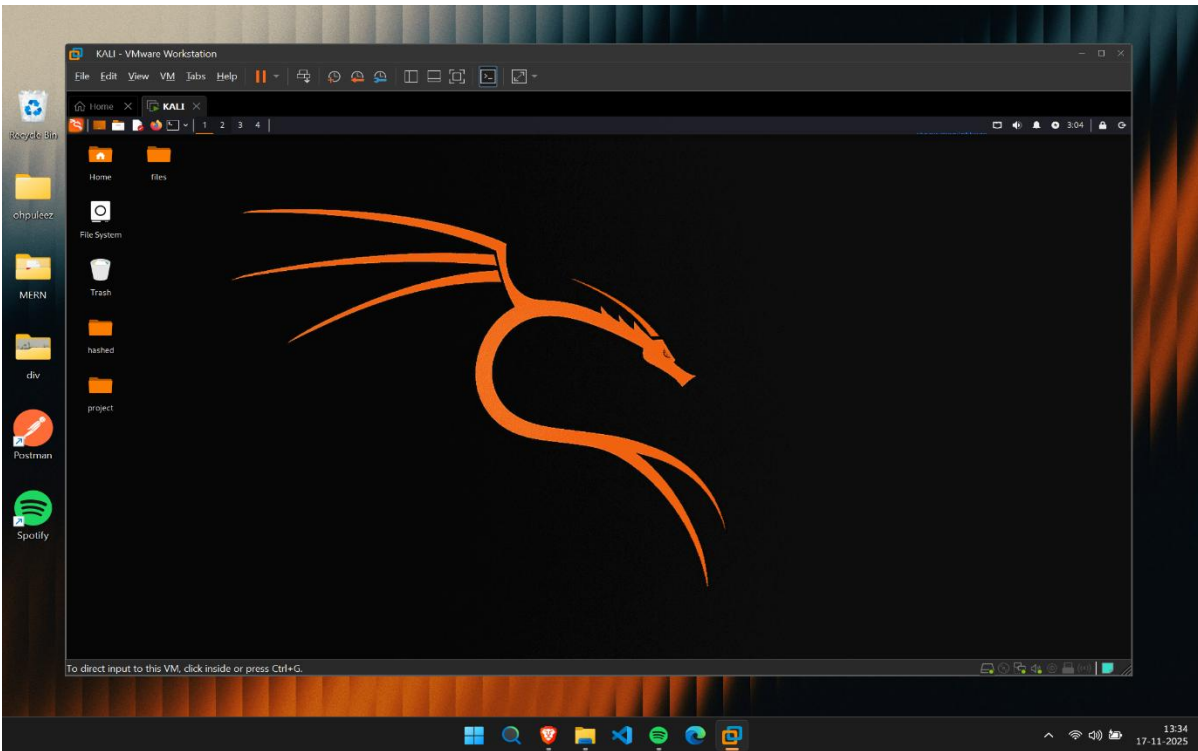
2. Investigation Methodology & Environment Setup

To preserve the integrity of the original evidence and protect production systems, all analysis was conducted in a strictly controlled environment.

2.1 Sandboxed Environment

- **Hypervisor:** VMware Workstation on a Windows 11 Host.
- **Guest Operating System:** Kali Linux (Isolated, network connectivity disabled during local file execution).

- **Evidence Handling:** The original .eml file was preserved as read-only; analysis was performed exclusively on a duplicate working copy.



Evidence Figure 1: Isolated Kali Linux sandbox environment utilized for forensic analysis.

3. Email Header & Authentication Forensics

A deep dive into the email headers reveals the true origin of the message, bypassing the spoofed display name.

3.1 Origin and Routing Path

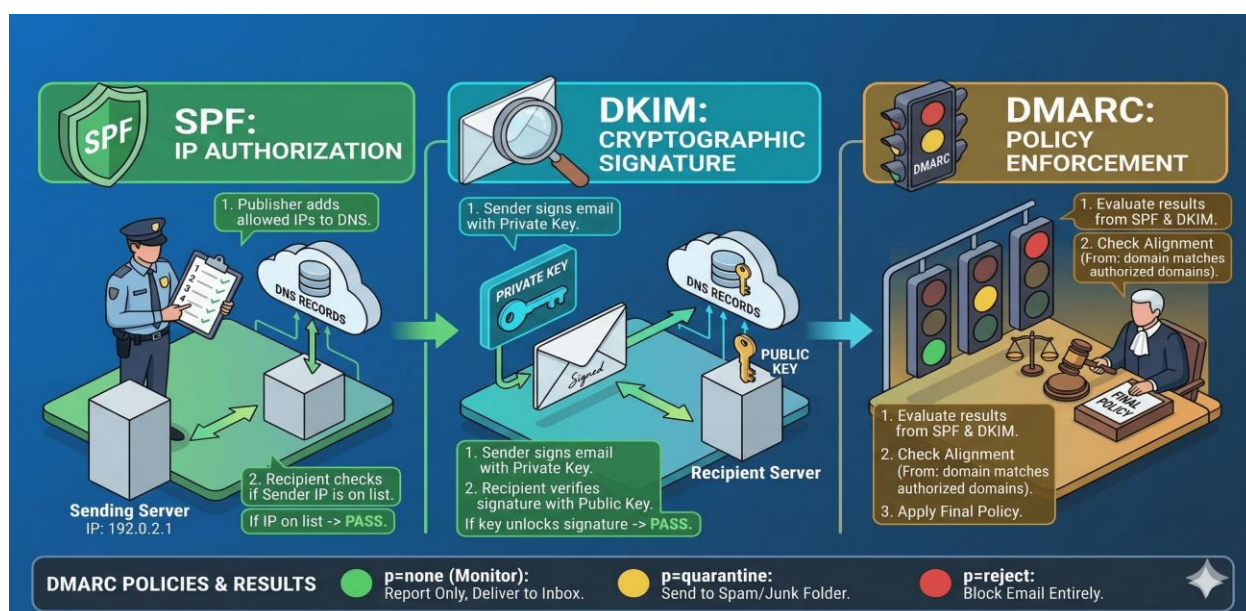
Trace analysis of the Received headers indicates the email did not originate from official PayPal infrastructure.

- **Origin Node:** The email was dispatched from a host named infected-pc located in Bulgaria (IP: 45.67.89.101). This hostname strongly suggests a compromised user machine operating as a botnet node for spam distribution.
- **Relay Node:** The message was then routed through suspicious.host in Switzerland (IP: 185.203.114.77) before reaching the target.



3.2 Sender Authentication Failures The threat actor attempted to impersonate PayPal using the address support@secure-paypal.com. Cryptographic and policy checks universally failed:

- **SPF (Sender Policy Framework): FAIL.** The domain secure-paypal.com explicitly rejected the sender IP (185.203.114.77) as an authorized sender.
- **DKIM (DomainKeys Identified Mail): NONE.** The message lacked a valid cryptographic signature.
- **DMARC: FAIL (Action: Quarantine).** Due to the combined SPF and DKIM failures, the receiving server's DMARC policy correctly flagged the message for quarantine, identifying it as unauthorized.



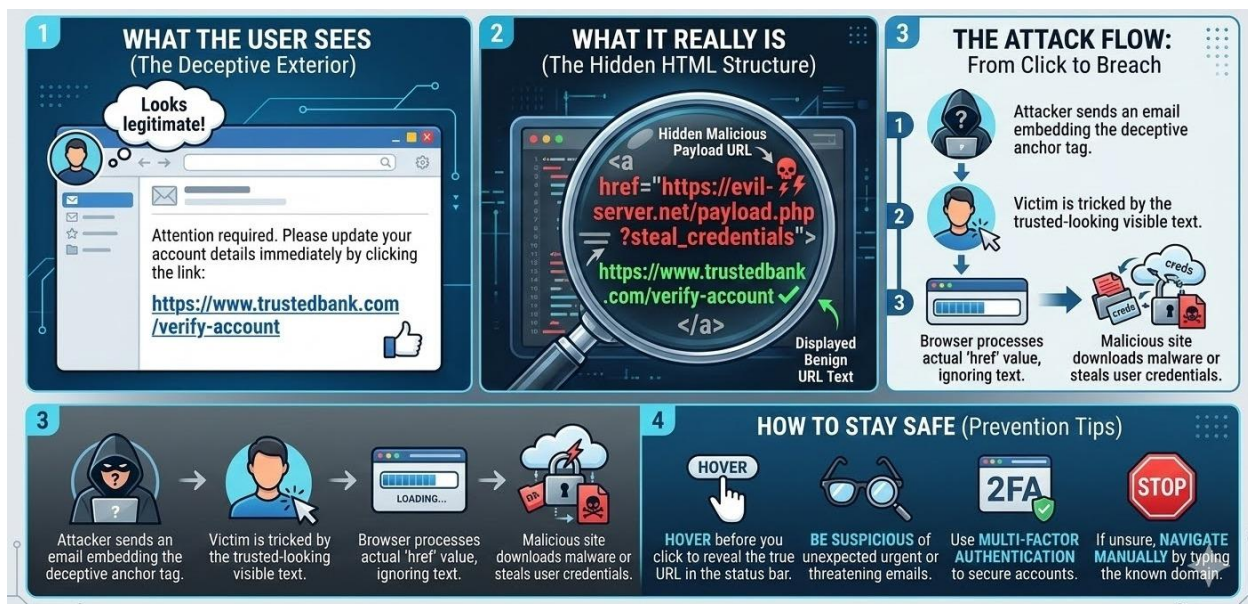
4. Content, Link, and Social Engineering Analysis

4.1 Psychological Triggers (Social Engineering)

The attacker utilized standard, yet effective, psychological manipulation to bypass the victim's critical thinking.

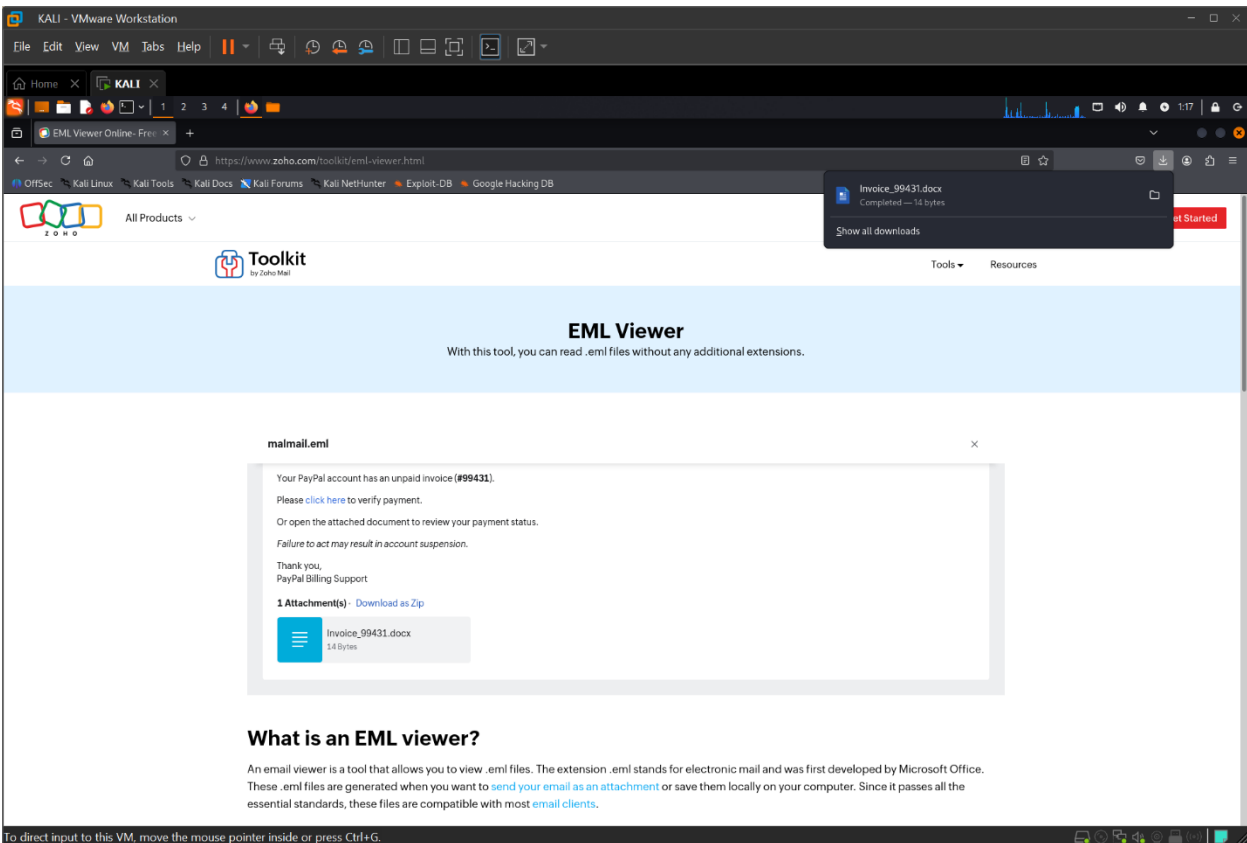
- **Manufactured Urgency:** The subject line ("Action Required: Invoice #99431 Pending") and body text ("Failure to act may result in account suspension") leverage fear and urgency to force immediate action.
- **Lack of Personalization:** The greeting "Dear Customer" confirms this is a spray-and-pray campaign rather than a highly targeted spear-phishing attack.

4.2 URL Obfuscation and Extraction The attacker employed HTML anchor tag manipulation to deceive the user and automated email scanners.



- **The Decoy:** The plain text version of the email displays the legitimate URL `https://paypal.com` to build false trust.

The Payload: The underlying HTML code redirects clicks to the malicious destination: `hxxps[:]//paypalphish[.]vercel[.]app/`.

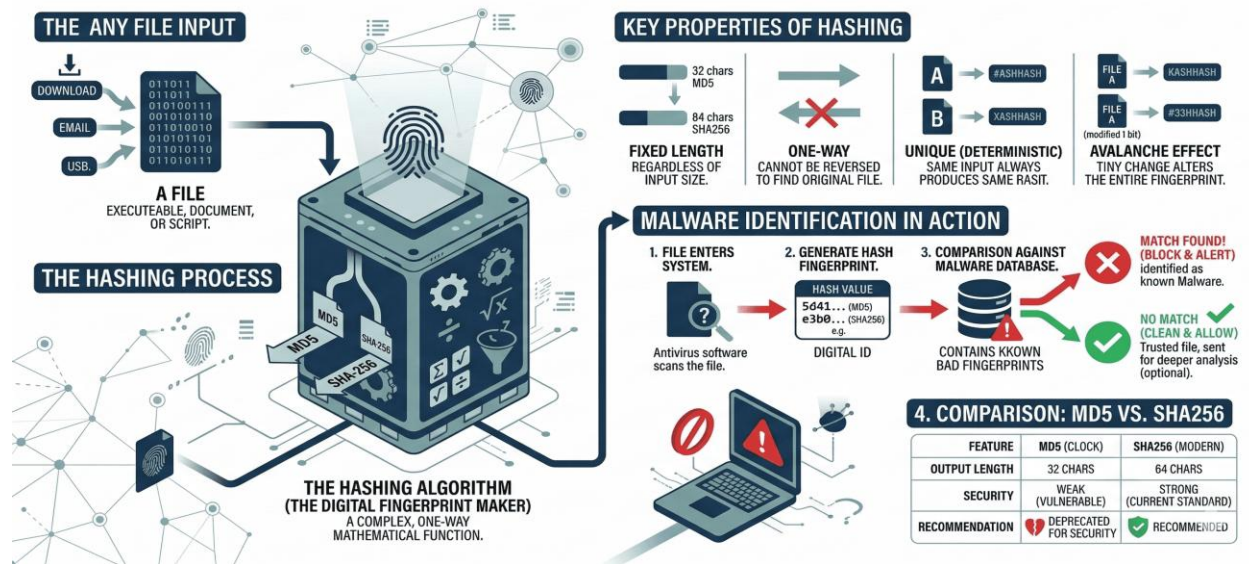


Evidence Figure 2: Analysis of embedded HTML anchor tags revealing the obfuscated link destination.

5. Attachment Forensics and Payload Assessment

The email contained a single attachment named Invoice_99431.docx. Due to the high risk of malicious macros, the file was handled under strict containment.

5.1 Cryptographic Fingerprinting Hashes were generated to uniquely identify the artifact for threat intelligence querying.



- **MD5:** bfe751b0ae122a3305f35f420d43be65
- **SHA-256:** 82bf93632480ca0c3e3856d671129bffe4910bd8a085e077afcb14ab0b12e7c

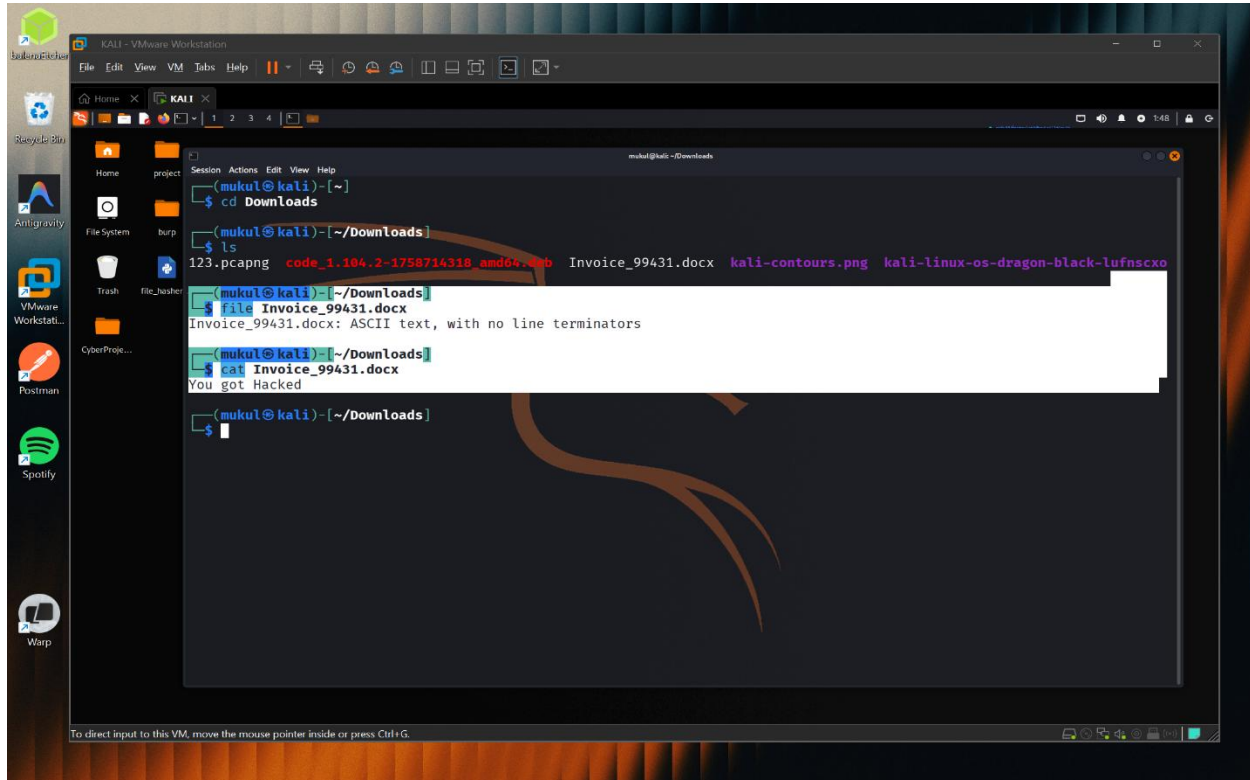
```

mukul@kali: ~/Downloads
$ ls
amazon-q.deb Desktop Documents Downloads Music Pictures Public Templates Videos
$ cd Downloads
$ ls
123.pcapng code_1.104.2-1758714330_amd64.deb Invoice_99431.docx kali-contours.png kali-linux-os-dragon-black-lufnscxo
$ md5sum Invoice_99431.docx
md5sum: Invoice_99431.docx: No such file or directory
$ md5sum Invoice_99431.docx
bfe751b0ae122a3305f35f420d43be65 Invoice_99431.docx
$ sha1sum Invoice_99431.docx
2a1529f5d152dd26ebe1ffa91af0eed08193c3ba Invoice_99431.docx
$ sha256sum Invoice_99431.docx
82bf93632480ca0c3e3856d671129bffe4910bd8a085e077afcb14ab0b12e7c Invoice_99431.docx
$
  
```

Evidence Figure 3: Generation of cryptographic hashes for the suspicious attachment via the CLI.

5.2 File Behavior & Reverse Engineering Despite the .docx file extension, the file command utility in Linux revealed the artifact was a simple ASCII text file. Opening the file in a safe text

editor revealed the string: "You got Hacked".



Evidence Figure 4: Extracted payload revealing a benign placeholder message rather than an active exploit.

Querying the SHA-256 hash against VirusTotal yielded a 0 vendor detection rate. This confirms the attachment is a benign placeholder or corrupted payload. However, the presence of the attachment heavily increases the click-through likelihood for the user.

6. Threat Intelligence Correlation & Framework Mapping

6.1 Open-Source Intelligence (OSINT) Findings

The extracted indicators of compromise (IOCs) were enriched using external threat intelligence platforms.

- **VirusTotal:** The phishing URL (`hxxps[:]//paypalphish[.]vercel[.]app/`) is flagged as malicious by 17 security vendors.

17 / 98 Community Score

17/98 security vendors flagged this URL as malicious

https://paypalphish.vercel.app/

Status: 451 | Content type: text/html; charset=utf-8 | Last Analysis Date: 26 days ago

text/html

REANALYZE SEARCH MORE

DETECTION DETAILS COMMUNITY

Security vendors' analysis

alphaMountain.ai	Phishing	BitDefender	Phishing
CRDF	Malicious	Criminal IP	Phishing
CyRadar	Phishing	ESET	Phishing
Forcepoint ThreatSeeker	Phishing	Fortinet	Phishing
G-Data	Phishing	Gridinsoft	Phishing
Kaspersky	Phishing	Lionic	Phishing
MalwareURL	Phishing	Phishing Database	Phishing
Sophos	Phishing	VIPRE	Phishing
Webroot	Malicious	Abusix	Clean

Evidence Figure 5: VirusTotal community detection results for the phishing URL.

- URLScan.io & Abuse.ch:** Infrastructure analysis confirms the domain is hosted on Vercel, resolving to IP 216.198.79.3 (Amazon-02, US). Further querying on Abuse.ch confirms related malicious activity targeting this IP space.

ABUSE.ch | SPAMHAUS TECHNOLOGY

Hunting False Positives API Logout

Hunting 216.198.79.3 Search Share

Summary URLhaus 23 MalwareBazaar ThreatFox YARAify Sandnet 22 IPIntel 100 ProxyCheck FP

23 results found in our malware distribution URL tracking platform URLhaus.

22 result(s) found in Sandnet

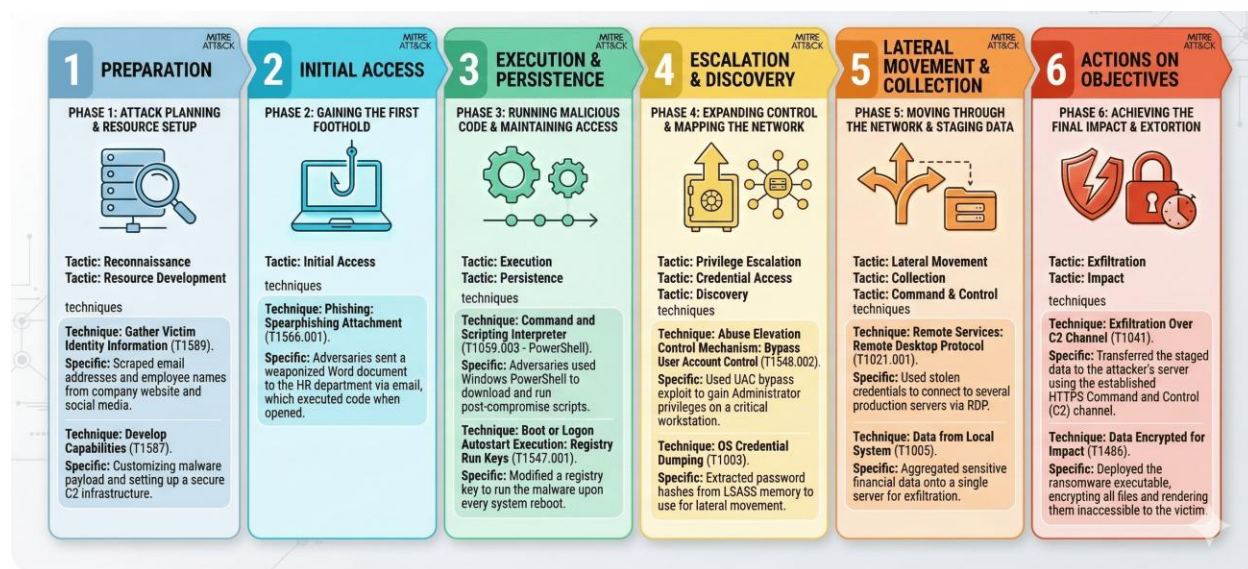
100 result(s) found in our IP fingerprinting service IPIntel.

Twitter LinkedIn Instagram Facebook

Terms and Conditions | Terms of Use | Privacy Policy | Cookie Policy

Evidence Figure 6: Abuse.ch threat intelligence correlation for the hosting IP address.

6.2 MITRE ATT&CK Framework Mapping



The adversary's behavior maps to the following recognized techniques:

- **T1566.002 (Phishing: Link):** Utilizing obfuscated malicious URLs in the email body.
- **T1036 (Masquerading):** Impersonating a trusted financial entity (PayPal).
- **T1583.006 (Acquire Infrastructure: Web Services):** Abusing legitimate cloud services (Vercel) to host phishing pages, thereby evading traditional domain reputation blocklists.

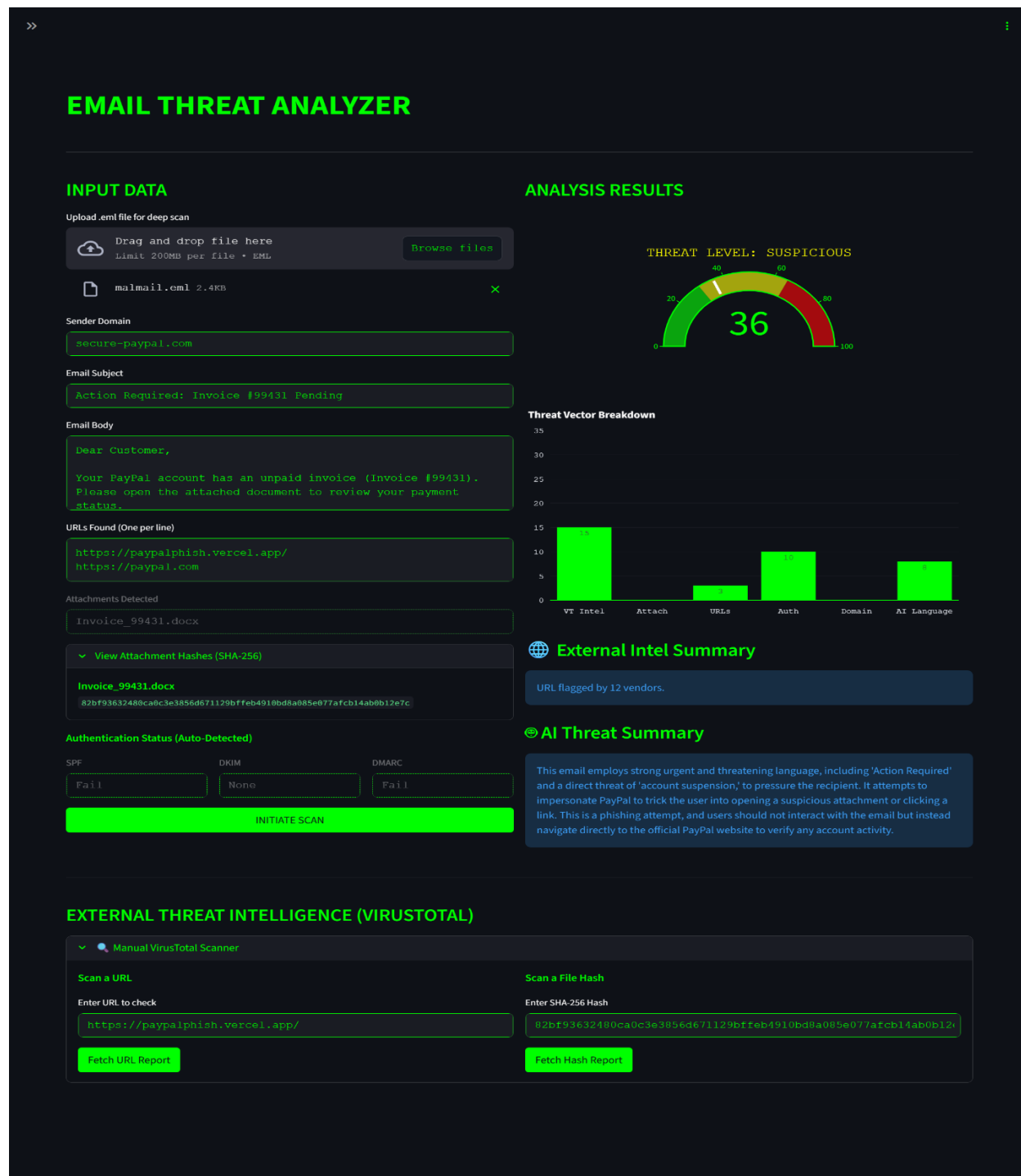
6.3 NIST Cybersecurity Framework (CSF) Alignment

- **Identify:** Brand impersonation and typosquatting serve as initial threat indicators.
- **Detect:** Successful detection occurred via URL reputation analysis (VirusTotal, URLScan.io).
- **Respond:** The email is classified, allowing for user notification and active network containment.
- **Protect:** Proactive defense requires DMARC enforcement and advanced gateway filtering.

7. Automated Threat Scoring Evaluation

To standardize incident response, a custom Python-based threat scoring system was

engineered, utilizing a 100-point weighted matrix .



Evidence Figure 7: Custom AI-Assisted Threat Scoring Dashboard visualizing the evaluated risk.

7.1 Scoring Matrix Breakdown

- Malicious Attachments: 0-30 points
- Suspicious URLs: 0-25 points
- SPF/DKIM/DMARC Failures: 0-20 points
- Suspicious Sender Domain: 0-15 points
- Urgent/Threatening Language: 0-10 points

7.2 System Output

The tool generated a score of **36/100 (Suspicious)**. The score is suppressed from the "Malicious" tier primarily because the attachment was a benign text file rather than a weaponized executable. However, human-in-the-loop correlation overrides this to a high-priority incident due to the successful cloud infrastructure abuse.

8. Actionable Recommendations and Remediation

To mitigate the immediate threat and harden the organization against future campaigns, the following steps must be implemented:

8.1 Immediate Containment (IOC Blocking) Add the following indicators to the firewall and email gateway blocklists:

- **Domains:** paypalphish.vercel.app, secure-paypal.com
- **IP Addresses:** 45.67.89.101, 185.203.114.77, 216.198.79.3

8.2 Strategic Preventive Controls

- **Enforce Strict DMARC Policy:** Transition the organization's DMARC policy to p=reject to completely neutralize domain spoofing attempts.
- **Enhanced Gateway Filtering:** Implement dynamic URL rewriting and sandbox detonation for all inbound emails. Automatically flag or quarantine emails originating from newly registered domains or frequently abused cloud hosts (like Vercel or AWS subdomains).
- **Security Awareness Training:** Deploy targeted training simulations mimicking invoice-based phishing and emphasizing the verification of actual link destinations by hovering

over embedded text.

9. References

1. VirusTotal. *URL and File Hash Reputation Intelligence*.
2. URLScan.io. *Website Scanner and Screenshot Capture*.
3. Abuse.ch. *Malware and IOC Database*.
4. MITRE Corporation. *MITRE ATT&CK Framework*.
5. NIST. *Cybersecurity Framework (CSF)*.
6. MXToolBox. *Email Header Analyzer*.